# TradeCheck AI: where it falls under the EU AI Act and the GDPR

Assessment of workflow **“Tradecheck shipment check v1.3”** (n8n) · Legal status as of 30 October 2026 · Prepared for Ayad Alsultan

This is a structured compliance analysis, not legal advice. Have a lawyer or your data protection officer confirm it before going live with real shipments.

## 1. The short answer

| Question | Answer | Why |
|---|---|---|
| Is TradeCheck an “AI system” under the AI Act? | **Yes** | It uses Gemini models to extract data, suggest HS codes and screen for injection. That is machine-based inference producing recommendations (Art. 3(1)). |
| Prohibited practice (Art. 5)? | **No** | No manipulation, social scoring, biometrics, emotion recognition or profiling of persons. |
| High-risk (Art. 6 + Annex I / III)? | **No** | Classifying *goods* for customs is not on the Annex III list. Point 7 (migration, asylum, border control) only covers systems that assess *natural persons*. Not a safety component of a regulated product (Annex I). |
| Transparency duties (Art. 50)? | **Borderline / low** | Not a chatbot, no deepfakes, no public-interest publishing. The only arguable point is Art. 50(2) machine-readable marking of AI-generated text in the report. Cheap to cover (section 3.5). |
| AI literacy (Art. 4)? | **Applies** | Applies to every provider and deployer regardless of risk tier. Since July 2026 the duty is to “take measures to support” literacy, not guarantee a level. |
| Does the GDPR apply? | **Not to the test set; yes in production** | The eval PDFs are synthetic (no real people). Real invoices, packing lists and certificates carry names of contact persons, signatories, sole traders, addresses and e-mails. That is personal data. |
| Automated decision under Art. 22 GDPR? | **No** | The output is a draft about goods for a licensed broker. Nothing is submitted, and no decision with legal effect on a person is made by the machine. |
| Biggest real GDPR gaps | **Action needed** | (1) Processor agreements, especially if Gmail/Docs/Sheets run on a consumer Google account. (2) Retention of reports, e-mails, the run log and n8n execution data. (3) Data minimisation: the full document text, including names, goes to the LLM. |

**Bottom line.** Under the AI Act, TradeCheck is a **minimal / limited-risk AI system**. Your obligations are AI literacy (Art. 4), a light transparency measure (Art. 50(2)), and keeping a short written record of why it is not high-risk. GDPR is the heavier regime in practice. Once real documents flow through, you are a controller (or a processor for a brokerage client) who uses Google, n8n and possibly Supabase as processors.

## 2. What the workflow actually does (and which law each step touches)

| Node(s) | What happens | AI Act | GDPR |
|---|---|---|---|
| Shipment Upload (form) | User uploads invoice, packing list, certificate of origin + shipment ID. | — | Collection of documents that may contain personal data of third parties (Art. 14 situation). |
| Invoice text / Packing_List / Origin Text | PDF → plain text inside n8n. | — | Processing; n8n stores execution data (incl. binaries) unless pruned. |
| Invoice / Packing List / Origin Extractor (Gemini 3.5 Flash-Lite) | LLM extracts structured fields. The invoice schema includes `seller` and `buyer` names. | **AI component.** Inference → structured output. | Full document text is sent to Google (processor, possible third-country transfer). Seller/buyer names are extracted but never used by the checks (minimisation issue). |
| Combine Texts → Injection Guard (Gemini 3.1 Flash-Lite) | Keyword + LLM screening for prompt injection. | AI component; also a **robustness / security measure**. | Second transfer of all document text to Google. Supports Art. 32 security. |
| Consistency Checker, Rules And Grounding, Router | Deterministic JavaScript: arithmetic, weight, origin checks, tariff grounding, confidence threshold, routing. | Not AI on its own, but part of the overall system. Acts as human-oversight design: uncertain → *human_review*. | Accuracy principle (Art. 5(1)(d)). No profiling of persons. |
| HS Classifier agent + tariff_search (Supabase vectors, Gemini embeddings) | Agent suggests up to 3 HS-6 codes grounded in tariff text; “no code” when unsure. | **Core AI function**: recommendations. | Only product descriptions + origin. Normally no personal data. The Supabase table holds tariff text only. |
| Tariff Reference, Restricted List (Google Sheets) | Reference data. | — | No personal data. |
| Build Report → Google Docs, Gmail, Run Log (Sheets) | Report with draft declaration, e-mailed to the broker, plus a log row. | Output carries the line “Generated by TradeCheck AI using Google Gemini” (human-readable disclosure). | Personal data now stored in Drive, Gmail and a Sheet with **no deletion rule**. Recipient e-mail is personal data. |

# 3. EU AI Act (Regulation (EU) 2024/1689, as amended by Regulation (EU) 2026/1744)

## 3.1 Current timeline that matters for you

The Digital Omnibus on AI was adopted as Regulation (EU) 2026/1744, published on 24 July 2026 and in force since 27 July 2026. Stand-alone Annex III high-risk obligations moved from 2 August 2026 to 2 December 2027, and Annex I product-embedded systems to 2 August 2028. The Article 50 transparency duties were **not** postponed and have applied since 2 August 2026. The only exception is a grace period to 2 December 2026 for machine-readable marking (Art. 50(2)), and it covers only generative systems already on the market before 2 August 2026.

| Date | Obligation | Relevance for TradeCheck |
|---|---|---|
| 2 Feb 2025 | Art. 4 AI literacy; Art. 5 prohibitions | **Applies now** / **n/a** |
| 2 Aug 2025 | General-purpose AI (GPAI) model obligations (Chapter V) | Google's duty for Gemini, not yours |
| 27 Jul 2026 | Omnibus in force; Art. 4 rewritten ("take measures to support") | Lighter literacy duty |
| 2 Aug 2026 | Art. 50 transparency; penalties enforceable | **Check 50(2)** |
| 2 Dec 2026 | End of 50(2) grace period for pre-August generative systems | Likely not relevant: TradeCheck goes live after Aug 2026, so 50(2) applies from day one if it applies at all |
| 2 Dec 2027 | Annex III high-risk obligations | **n/a** unless the purpose changes |

## 3.2 Is it an AI system, and who are you?

- **AI system (Art. 3(1)).** Yes. The Gemini-based extractors, the classifier agent and the LLM guardrail infer, from input, how to generate outputs (content, recommendations) that influence a decision (the broker's declaration). The deterministic code nodes are part of the same system.
- **Provider (Art. 3(3)).** You build TradeCheck and put it into service under your own name, which makes you the provider. Wiring an off-the-shelf model into your own product makes you a *downstream provider*.
- **Deployer (Art. 3(4)).** Whoever uses it professionally: you, or a customs brokerage you give it to.
- **Google.** Google is the provider of a GPAI model (Gemini). The Chapter V GPAI obligations are Google's, not yours. You are entitled to the downstream information that GPAI providers must give.

## 3.3 Prohibited practices (Art. 5): not engaged

TradeCheck does none of the following: subliminal or manipulative techniques, exploiting vulnerabilities, social scoring, predictive policing of persons, facial-image scraping, emotion recognition, biometric categorisation or remote biometric identification. Nothing in the workflow processes biometric data or evaluates people.

### 3.4 High-risk classification (Art. 6): not high-risk

**Route 1, Annex I (Art. 6(1)).** TradeCheck is not a product, or a safety component of a product, covered by EU harmonisation legislation (machinery, medical devices, toys, vehicles…). **Not met**

**Route 2, Annex III (Art. 6(2)).** Each of the eight areas, checked against the workflow:

| Annex III area | Fit with TradeCheck |
|---|---|
| 1 Biometrics | No biometric data. |
| 2 Critical infrastructure | Not a safety component of utilities, traffic or digital infrastructure. |
| 3 Education | No. |
| 4 Employment / workers | Not used to recruit, evaluate or monitor staff. *Watch-out:* do not reuse the run log to rate brokers' or clerks' performance. |
| 5 Essential services (credit, insurance, public benefits, emergency) | No creditworthiness or insurance pricing of persons. |
| 6 Law enforcement | Used by private traders/brokers, not by law-enforcement authorities, and does not assess persons. |
| **7 Migration, asylum and border control** | **The closest area, and still out of scope.** The Commission's AI Act Service Desk guidance reads point 7 as covering tools such as polygraphs, person-level risk assessments and examination of asylum/visa applications. It treats object-level screening that is not mapped to a person as outside the use case (its example is flagging stolen vehicles at a crossing). TradeCheck classifies *goods* and checks *document consistency*. It produces no person-level risk output. |
| 8 Justice and democratic processes | No. |

**Conclusion: not high-risk.** Because TradeCheck is not an Annex III use case at all, you do *not* need the Art. 6(3) "filter" exemption. You also do *not* need EU-database registration, which only applies to systems that fall under Annex III and are exempted via 6(3). Keep a one-page internal note recording this reasoning and the intended purpose.

**What would change the answer.** Re-run this assessment if TradeCheck is ever (a) sold to or used by a customs authority to risk-score importers or travellers as persons; (b) extended to score the reliability of individual traders (sole traders are natural persons); or (c) used to decide on staff. Each of these could pull it into Annex III point 6, 7 or 4, or turn it into profiling.

### 3.5 Transparency (Art. 50): the only "limited-risk" touchpoint

| Paragraph | Duty | TradeCheck |
|---|---|---|
| 50(1) interaction with persons | Tell people they are interacting with an AI system, unless obvious. | Not a conversational system. The form and the report already say "TradeCheck AI … using Google Gemini". **Covered** |

| | | |
|---|---|---|
| 50(2) marking of synthetic content | Providers of systems that generate synthetic text must mark outputs in a machine-readable, detectable way. The Act exempts systems that only perform an assistive function for standard editing or do not substantially alter the input. | **Borderline.** Most output is extraction (not altering input) or deterministic code. The HS "reason" sentences and review reasons are model-generated text. **Low-cost fix:** add a machine-readable marker to every output (see actions). |
| 50(3) emotion recognition / biometric categorisation | Inform exposed persons. | **n/a** |
| 50(4) deepfakes / AI text published on matters of public interest | Deployers must label. | **n/a**. Reports are private business documents. |

Penalty ceiling for breaching Art. 50: up to EUR 15 million or 3% of worldwide annual turnover, whichever is higher (lower for SMEs under Art. 99(6)).

### 3.6 AI literacy (Art. 4): applies

The Omnibus rewrote Art. 4. Providers and deployers must still take measures to support the AI literacy of staff and others operating AI on their behalf, but they no longer have to guarantee any specific level for any individual. For TradeCheck this means a short, documented briefing for every broker or clerk who reads the reports. It should cover: the HS suggestion is a draft; what "NO CODE SUGGESTED", low confidence and the injection flag mean; that Gemini can be wrong; and that the broker remains responsible for the declaration.

### 3.7 Good practice you already have (worth documenting)

None of these are mandatory for a non-high-risk system. They mirror the high-risk requirements, though, and they make a strong case to a client or regulator:

- **Human oversight (cf. Art. 14):** the system never submits; uncertain lines get "NO CODE SUGGESTED"; any issue routes to human_review.
- **Accuracy and robustness (cf. Art. 15):** tariff grounding (code must exist in the reference sheet); confidence threshold; extractor rule "never guess numbers"; an evaluation set with an answer key (TEST-03…22).
- **Cybersecurity (cf. Art. 15(5)):** prompt-injection rules in every system prompt plus a separate guardrail node.
- **Record-keeping (cf. Art. 12):** run_log with route and reasons per shipment.
- **Voluntary codes of conduct (Art. 95)** are available if you want to signal this formally.

## 4. GDPR (Regulation (EU) 2016/679)

> **Status note.** The Commission's "Digital Omnibus" on data proposes GDPR changes, among them a narrower definition of personal data and a new Art. 88c legitimate-interest basis for AI. The EDPB and EDPS strongly opposed parts of it in Joint Opinion 2/2026, and it is still in the legislative process. This analysis applies the GDPR **as currently in force**.

### 4.1 Is there personal data?

- **Test phase:** the eval set is marked "SYNTHETIC TEST DOCUMENT… NOT A REAL TRANSACTION" and uses fictional companies. That is not personal data, so the GDPR is not triggered.

- **Production:** company data as such is not personal data. Real trade documents, however, routinely include **contact persons, signatories, phone numbers and e-mails, sole traders** (whose business name identifies a person), and sometimes private consignees. The broker's e-mail address in the Gmail node is personal data too. **GDPR applies**. No special-category data (Art. 9) is expected.

### 4.2 Roles

| Party | GDPR role | Comment |
|---|---|---|
| You, running TradeCheck for your own brokerage or import business | Controller | You decide why and how the documents are processed. |
| You, offering TradeCheck to brokerage clients | Processor (client = controller) | You need an Art. 28 data processing agreement with each client, and you must list your sub-processors. |
| Google: Gemini API | Processor | On paid services Google does not use prompts or responses to improve its products. It processes them under its data processing addendum and logs them only for a limited period for abuse detection and legal disclosures. Users in the EEA, Switzerland and the UK get these paid-service terms even on unpaid quota. |
| Google: Docs, Sheets, Gmail, Drive | Processor *only under Workspace* | **Check.** If the credentials ("Gmail account", "Google Docs account") are a consumer @gmail.com account, there is no Art. 28 processor agreement for business data. Move to Google Workspace (with its Cloud Data Processing Addendum) before handling real documents. |
| n8n (cloud or self-hosted host) | Processor | Holds execution data, including uploaded PDFs. You need a DPA with n8n Cloud or with your hosting provider. |
| Supabase | Processor (if any personal data) | Currently stores tariff vectors only, so no personal data. Keep it that way. |

### 4.3 Lawful basis (Art. 6)

The most defensible basis is **legitimate interest, Art. 6(1)(f)**: checking trade documents for errors before a customs declaration. Its impact on contact persons is low, and they would reasonably expect it. Write a short legitimate-interest assessment (purpose, necessity, balancing). Where you act for a client, the client chooses the basis. Art. 6(1)(b) (contract) can support processing data of your own counterparties. No consent is needed.

### 4.4 Principles (Art. 5) mapped to the workflow

| Principle | Current state | Gap / fix |
|---|---|---|
| Purpose limitation | Single purpose: pre-declaration check. | Do not reuse documents or logs for model training or for rating people. |
| Data minimisation | Whole PDF text goes to Gemini 4× (three extractors + guardrail). The invoice schema extracts `seller` and `buyer`, which no check uses. | Remove `seller` / `buyer` from the extractor schema. Optionally mask e-mails and phone numbers with a regex before the LLM calls. Only product descriptions go to the classifier: good. |

| | | |
|---|---|---|
| Accuracy | Strong: arithmetic checks, grounding, human review. | — |
| Storage limitation | Reports in Drive, e-mails in Gmail, run_log rows, n8n executions: kept indefinitely. | Set retention: e.g. delete n8n execution data after 14–30 days (execution pruning), and set a deletion rule for Docs and e-mails that matches your customs record-keeping period. Keep the run_log free of names. |
| Integrity and confidentiality (Art. 32) | Injection guard; OAuth credentials; the form is a public webhook. | Put authentication on the n8n form (currently anyone with the URL can upload). Restrict Drive folder sharing. Limit who can open the run_log. |
| Accountability | — | Record of processing activities (Art. 30), LIA, DPA list, this assessment. |

### 4.5 Transparency to data subjects (Art. 13/14)

The people named in the documents did not give you their data directly, so Art. 14 applies. A privacy notice on your (or your client's) website should name the purpose, the legitimate interest, the recipients (Google, n8n), any transfers and the retention period. That is normally enough. Contacting each person individually would be disproportionate (Art. 14(5)(b)).

### 4.6 Automated decision-making (Art. 22): not triggered

Art. 22 covers decisions *based solely* on automated processing that produce legal or similarly significant effects *on a person*. TradeCheck's outputs concern goods. Routing to "ready for broker" or "human review" is internal triage, and a licensed broker makes and submits the declaration. Keep it that way: never allow automatic submission, and never auto-reject a trader.

### 4.7 International transfers (Chapter V)

Google's terms allow data to be stored transiently or cached in any country where Google or its agents have facilities. Transfers to the US are covered by the EU-US Data Privacy Framework (Google is certified) and by standard contractual clauses in Google's DPA. Mention this in your record of processing and in the privacy notice. For stricter data residency, Gemini via Vertex AI in an EU region is the alternative.

### 4.8 DPIA (Art. 35): likely not mandatory

There is no large-scale special-category data, no systematic monitoring and no evaluation of persons. That keeps TradeCheck outside the Art. 35(3) cases and, as far as can be assessed, outside the German DSK "must-do" list. New technology (LLMs) is one criterion, but on its own it normally does not require a DPIA. **Record a short screening** explaining why no DPIA was done. Revisit it if volumes become large or the purpose changes.

## 5. Action checklist (priority order)

| # | Law | Action | When |
|---|---|---|---|
| 1 | GDPR | Move Gmail, Docs, Sheets and Drive from consumer accounts to Google Workspace with the Cloud Data Processing Addendum. Confirm the Gemini API project is billed or on EEA terms. | Before real data |

| | | | |
|---|---|---|---|
| 2 | GDPR | Sign or accept DPAs with n8n (or your host) and Supabase. Keep a sub-processor list. | Before real data |
| 3 | GDPR | Protect the upload form with authentication. | Before real data |
| 4 | GDPR | Retention: enable n8n execution pruning; define deletion periods for Docs, e-mails and run_log. | Before real data |
| 5 | GDPR | Minimise: drop `seller` / `buyer` from the extractor schema; optionally mask e-mails and phone numbers before LLM calls. | Next sprint |
| 6 | GDPR | Write the record of processing (Art. 30), legitimate-interest assessment, DPIA screening note and privacy notice text. | Before real data |
| 7 | AI Act | Add machine-readable AI marking: e.g. an `ai_generated: true, model: gemini-3.5-flash-lite` field in the JSON output, an `X-AI-Generated` mail header or tag, and a line in the Doc description. Keep the visible "Generated by TradeCheck AI using Google Gemini". | Now (Art. 50 applies) |
| 8 | AI Act | AI literacy: a 1-page user guide plus a short briefing for every broker; keep a record of who received it. | Now |
| 9 | AI Act | File an internal note: intended purpose, "not Annex III" reasoning (section 3.4), triggers for reassessment. | Now |
| 10 | Both | Keep the evaluation set and results per version (v1.2, v1.3…) as evidence of accuracy testing. | Ongoing |

## 6. Sources


- Regulation (EU) 2024/1689 (AI Act), Arts. 3, 4, 5, 6, 50, 95, 99, 113; Annex I and III. Regulation (EU) 2016/679 (GDPR), Arts. 4–6, 13–14, 22, 25, 28, 30, 32, 35, 44–49.
- Cooley, "Digital AI Omnibus Delays Key Deadlines, Introduces New Rules" — cdp.cooley.com/digital-ai-omnibus-delays-key-deadlines-introduces-new-rules/
- Cloud Security Alliance, "EU AI Act High-Risk Deadline Pushed to December 2027" — labs.cloudsecurityalliance.org
- Orrick, "EU AI Act Update: Digital Omnibus Finalizes 8 Compliance Changes" (July 2026) — orrick.com
- Stibbe, "The AI Act's Transparency Obligations: Rules, Scope and Timeline" — stibbe.com
- Mishcon de Reya, AI Act transparency obligations, Code of Practice and draft guidelines — mishcon.com
- European Commission AI Act Service Desk, Annex III point 7 (migration, asylum and border control) — ai-act-service-desk.ec.europa.eu/node/467
- Presencis / Opsio summaries of amended Art. 4 (AI literacy) under Regulation (EU) 2026/1744
- Gemini API Additional Terms of Service (paid services data use), as quoted in github.com/google-gemini/gemini-cli/issues/1472 and simonwillison.net (17 Oct 2024)
- Lexgo, "The Digital Omnibus: GDPR Update" (29 Apr 2026) and Innovires summary of EDPB-EDPS Joint Opinion 2/2026